المدرسة الوطنية العليا للذكاء الاصطناعي وعلوم المعطيات - تارودانت
ⵜⵉⵎⵔⵔⴰⵜ ⵜⴰⵏⴰⵎⵓⵔⵜ ⵜⴰⵏⴰⵅⵍⵉⵏⵜ ⵏ ⵡⴰⵏⴰⵎⵓⵔ ⴰⴷⵣⵢⵓ ⴰ ⵜⵎⴰⵡⴰⵙⵜ ⵏ ⵜⵣⵔⴼⵜ - ⵜⴰⵔⵓⴷⴰⵏⵜ
ÉCOLE NATIONALE SUPÉRIEURE DE L'INTELLIGENCE ARTIFICIELLE ET SCIENCES DES DONNÉES – TAROUDANT

M352

Sécurité de la virtualisation et du Cloud Computing

Filière : Sécurité IT et Confiance Numérique

CH2 - Fournisseurs, composants, SecaaS, responsabilité partagée et premiers risques

Prof. AGALIT Mohamed Amine



Objectifs et parcours du chapitre

Problème de l’architecture Cloud
Acteurs, fournisseurs et architecture de référence
Composants techniques : régions, réseaux, stockage, management plane
Activité 1 + fournisseurs : lecture d’architecture
SecaaS et intégration des services de sécurité
Responsabilité partagée : le fournisseur et le client ont chacun une partie du travail
Surface d’attaque Cloud + mini-cas
Quiz

Comment passer d’un modèle Cloud à une architecture sécurisée



Idée centrale : une architecture devient sûre lorsque l’on sait où sont les données, quels flux sont autorisés et qui protège chaque couche.

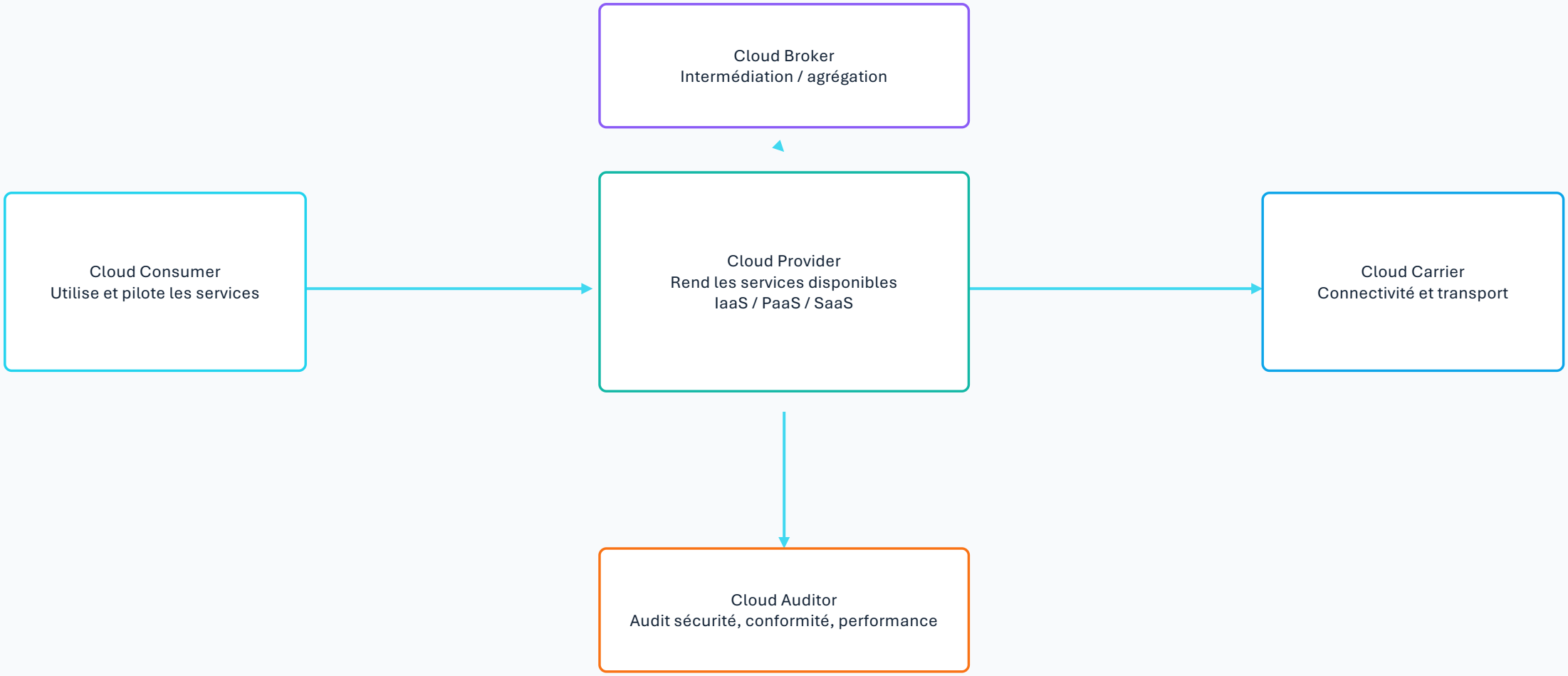
Fil rouge : comment ENSIA-Tech peut migrer vers le Cloud en sécurité ?

Contexte
Une école d'ingénieurs veut héberger un portail étudiant, une base de données, un stockage de documents, des journaux et un accès administrateur distant.

Contraintes
Disponibilité, sécurité, coût maîtrisé, accès distant, séparation public/privé, traçabilité, sauvegarde et gestion des comptes.

Question :
Quels composants Cloud choisir ? Où placer les contrôles ? Quelles surfaces d'attaque apparaissent ?

Architecture de référence NIST : les acteurs du Cloud



Une architecture Cloud est un écosystème d'acteurs : la sécurité dépend de leurs responsabilités et de leurs interactions.

Architecture Cloud : six couches à examiner de bas en haut

Applications / données	Portail, API, bases, fichiers
Services managés	DBaaS, storage, fonctions, containers
Calcul virtualisé	VM, images, autoscaling, load balancer
Réseau virtuel	VPC/VNet, subnets, routes, firewall
Identité & management plane	IAM, console, API, logs, policies
Infrastructure fournisseur	Datacenters, hardware, hyperviseur, backbone

Sécurité transversale : identité, chiffrement, logs et supervision

Activité 1 • Construire une première architecture logique

10 minutes

À partir des besoins d'ENSIA-Tech, répondez aux questions suivantes :

1. Quels services doivent être accessibles aux étudiants depuis Internet ?
2. Quels composants doivent rester inaccessibles directement depuis Internet ?
3. Où faut-il placer la base de données ?
4. Comment l'administrateur doit-il accéder à l'environnement ?
5. Quelles informations doivent être journalisées et sauvegardées ?

1. portail ou point d'entrée dans la zone publique ;
2. application dans une zone privée ;
3. base de données dans une zone isolée ;
4. administration par VPN ou bastion ;
5. centralisation des journaux et sauvegardes protégées.

Région, zone de disponibilité et Edge : trois emplacements différents

Région
Zone géographique composée de plusieurs emplacements techniques. Sert à rapprocher les services des utilisateurs, gérer la résidence des données et organiser la résilience.

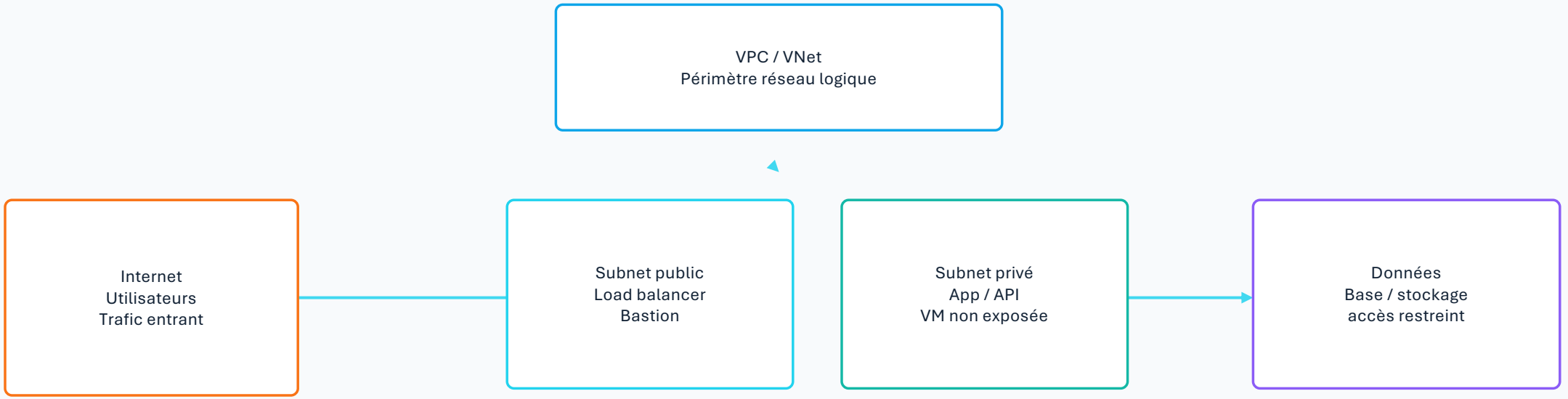
Zone de disponibilité
Emplacement isolé dans une région. Permet de limiter l'impact d'une panne et de concevoir une haute disponibilité.

Edge / CDN
Points proches des utilisateurs : distribution de contenu, réduction de latence, filtrage en périphérie, protection contre certains pics de trafic.

Question sécurité

Où sont stockées les données ? Que se passe-t-il si une zone tombe ? Qui administre les composants régionaux ?

Réseau virtuel : VPC / VNet / sous-réseaux



Un réseau Cloud bien conçu réduit l'exposition : tout ne doit pas être accessible depuis Internet, même si tout peut être créé en quelques clics.

Entrées, sorties et distribution de trafic

Internet Gateway
Donne une connectivité entre le réseau virtuel et Internet. Mauvais routage = exposition non voulue.

NAT Gateway
Permet à des ressources privées de sortir vers Internet sans être directement accessibles en entrée.

Load Balancer
Répartit le trafic et peut devenir un point de terminaison TLS ou un point d'inspection.

Bastion / VPN
Point contrôlé pour l'administration. Doit être fortement protégé et journalisé.

Données et stockage : objets, blocs, fichiers, bases

- Stockage objet : fichiers, sauvegardes, documents, journaux exportés.
- Stockage bloc : disques attachés aux VM.
- Stockage fichier : partages accessibles par plusieurs systèmes.
- Bases managées : SQL/NoSQL, configuration réseau et authentification.
- Sauvegardes et snapshots : très utiles, mais aussi sensibles.



Règle de prudence
Un stockage Cloud ne doit jamais être public par accident : accès, chiffrement, logs et cycle de vie doivent être vérifiés.

Plan de gestion et plan de données : deux types d’accès à protéger

Management plane
Console Cloud, API, IAM, politiques, création/suppression de ressources, clés, journaux, automatisation.

Question sécurité : qui peut modifier l’architecture ?

Data plane
Trafic applicatif, données, requêtes utilisateur, flux réseau, accès aux bases, fichiers et applications.

Question sécurité : qui peut accéder aux données et aux services ?

Point clé
Dans le Cloud, contrôler le management plane est aussi important que filtrer les ports réseau.

Fournisseurs Cloud : raisonner par familles de services

Hyperscalers
AWS
Microsoft Azure
Google Cloud

Large catalogue, automatisation avancée, services managés.

Clouds régionaux
OVHcloud, Scaleway, fournisseurs locaux ou souverains.

Intérêt : proximité, conformité, coût, souveraineté.

Cloud privé
VMware, OpenStack, Nutanix, Proxmox selon contexte.

Contrôle interne plus fort, mais responsabilités internes plus larges.

SaaS spécialisés
Messagerie, collaboration, CRM, sauvegarde, sécurité.

Risques : identité, données, intégrations.

Même fonction, noms différents selon fournisseur

Fonction	AWS	Azure	Google Cloud	Question sécurité
VM / calcul	EC2	Virtual Machines	Compute Engine	OS, patchs, accès admin
Réseau virtuel	VPC	VNet	VPC	Segmentation, routes, exposition
Pare-feu logique	Security Groups / NACL	NSG	Firewall Rules	Flux autorisés/interdits
Stockage objet	S3	Blob Storage	Cloud Storage	Public/private, chiffrement, logs
Identité	IAM	Entra ID / RBAC	IAM	Moindre privilège, MFA
Logs	CloudTrail/CloudWatch	Monitor/Activity Logs	Cloud Logging/Audit Logs	Détection, preuve, incident

Ne pas apprendre les noms par cœur : apprendre la fonction de sécurité derrière chaque service.

Méthode : relier chaque composant à un contrôle et à une preuve



Réflexe ingénieur
Chaque service Cloud doit être accompagné d'une décision de sécurité explicite, sinon il devient une surface d'attaque non maîtrisée.

Activité 2 • Associer service et contrôle

10 minutes

Associez chaque élément au contrôle prioritaire :

VM publique, base de données, bucket de documents, console admin, API exposée, journaux.

Contrôles possibles : IAM, firewall, chiffrement, logs, sauvegarde, WAF/API Gateway.

Élément	Risque principal	Contrôle prioritaire	Justification
VM publique	Exposition réseau	Firewall + durcissement + logs	Limiter les ports et tracer les accès
Base de données	Exfiltration	Réseau privé + chiffrement + IAM	Les données ne doivent pas être exposées directement
Bucket documents	Accès public accidentel	Politique d'accès + chiffrement + logs	Le stockage Cloud est une source fréquente de fuite
Console admin	Contrôle total possible	MFA + moindre privilège + audit	Le management plane modifie l'architecture
API exposée	Abus applicatif	API Gateway/WAF + auth + logs	Les API sont des points d'entrée automatisables
Journaux	Absence de preuve	Centralisation + immutabilité partielle	Les logs servent à détecter et enquêter

Security as a Service : utiliser une fonction de sécurité fournie comme service

Le fournisseur fournit l’outil. Le client doit encore le connecter, le configurer, surveiller ses alertes et vérifier son efficacité.



SecaaS : six familles de services et leur rôle

IAM / MFA
Identity and Access Management/Multi-Factor Authentication
identités, rôles, privilèges

KMS (**Key Management Service**)/ secrets

clés, chiffrement, secrets

WAF (Web Application Firewall)/ API security
filtrage Web et API

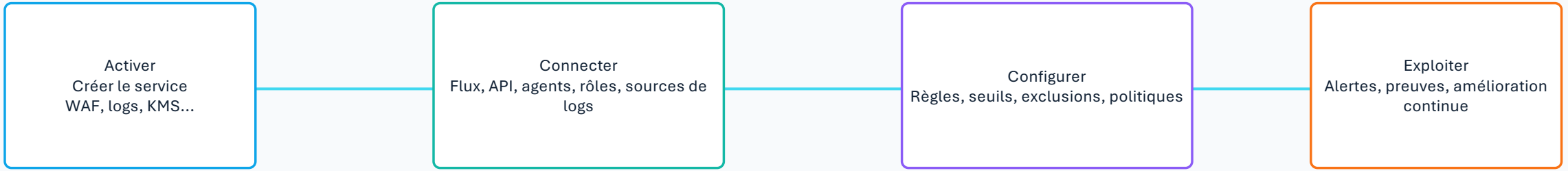
SIEM (Security Information and Event Management) / logs
centralisation, détection

CSPM **(Cloud Security Posture Management)** / posture
écarts de configuration

Backup / DR (Disaster Recovery ou Plan de Reprise d'Activité - PRA en français)
restauration et résilience

Limite importante
Souscrire à un service de sécurité ne remplace pas la conception, la configuration, la supervision et la responsabilité du client.

Intégrer un service de sécurité : le service seul ne suffit pas



Exemple
Un SIEM sans logs envoyés, sans règles et sans analyste n’est qu’une plateforme vide.

Responsabilité partagée

Plus le service est géré par le fournisseur, moins le client administre l’infrastructure. Il reste toutefois responsable de ses comptes, de ses données et de ses réglages.



Responsabilité partagée : le cœur du raisonnement Cloud

Couche / responsabilité	IaaS	PaaS	SaaS
Datacenter, matériel, réseau physique	Fournisseur	Fournisseur	Fournisseur
Virtualisation / plateforme de base	Fournisseur	Fournisseur	Fournisseur
OS et correctifs système	Client	Souvent fournisseur	Fournisseur
Application	Client	Client	Fournisseur
Données	Client	Client	Client / partagé
Identités et accès	Client	Client	Client
Configuration de sécurité	Client	Partagée	Partagée

À retenir : le fournisseur protège l'infrastructure du Cloud. Le client protège ses usages, ses accès, ses données et les éléments qu'il configure.

Activité 3 • Qui est responsable ?

7 minutes

Pour chaque incident, dites si la responsabilité est plutôt fournisseur, client ou partagée :

1) panne électrique datacenter ;
2) compte admin sans MFA ;
3) bucket public par erreur ;
4) vulnérabilité dans l'application ;
5) défaut sur l'hyperviseur.

Incident	Responsabilité	Justification
Panne électrique datacenter	Fournisseur	Infrastructure physique et disponibilité de la plateforme
Compte admin sans MFA	Client	Configuration des identités et accès
Bucket public par erreur	Client	Mauvaise configuration de l'accès aux données
Vulnérabilité application	Client	Code et application métier du client
Défaut hyperviseur	Fournisseur	Couche de virtualisation sous-jacente

Surface d’attaque Cloud : tous les points qu’un attaquant peut tenter d’exploiter

Pour analyser une architecture, cherchez les comptes puissants, les interfaces accessibles, les données sensibles et les réglages dangereux.



Cinq zones de risque à lire dans toute architecture Cloud

Identités
Comptes admin, clés, rôles trop larges, absence de MFA

API / Console
Actions automatisées, tokens, permissions, logs de contrôle

Réseau
Ports ouverts, routes, VPN, firewalls, interfaces publiques

Stockage / données
Buckets publics, snapshots, chiffrement, sauvegardes

Logs / supervision
Journaux absents, alertes ignorées, preuves incomplètes

Question réflexe
Qu’est-ce qui peut être modifié, exposé, consulté ou supprimé ?

Scénarios typiques d’exposition

Stockage public
Un espace de stockage contenant des copies de documents est rendu public par erreur.

Contrôles : politique d’accès, chiffrement, logs, détection de public exposure.

Administration exposée
Une interface SSH/RDP ou console d’administration reste accessible depuis Internet.

Contrôles : VPN/bastion, MFA, règles réseau, journaux.

Identité surprivilégiée
Un compte ou service account possède plus de droits que nécessaire.

Contrôles : moindre privilège, revues d’accès, rotation des clés.

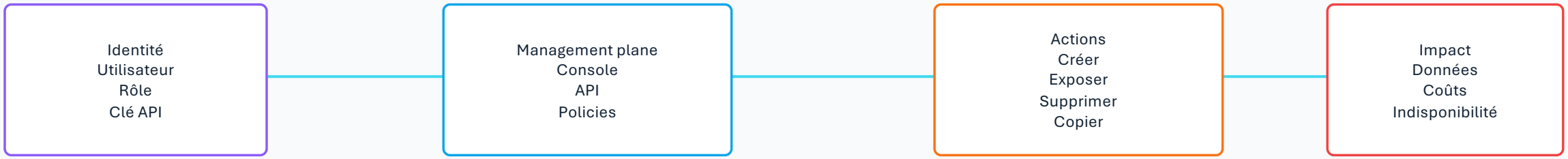
La mauvaise configuration : risque central du Cloud



- Création rapide de ressources sans revue.
- Règles firewall trop larges.
- Stockage accessible publiquement.
- Comptes de service permanents et clés non renouvelées.
- Logs non activés ou non consultés.
- Absence d’inventaire fiable.

Le Cloud ne crée pas seulement des vulnérabilités techniques : il accélère aussi les erreurs humaines et organisationnelles.

L’identité devient le principal périmètre de sécurité du Cloud



Message clé
Dans le Cloud, une identité trop puissante peut être plus dangereuse qu’un port ouvert.

Mini-cas ENSIA-Tech : lire l’architecture zone par zone

Besoins
Portail Web étudiant
Base de données
Documents
Administration distante
Logs et sauvegardes

Architecture attendue
Zone publique : LB (**Load Balancer)**/WAF
Zone privée : application
Zone données : DB/storage
Accès admin : VPN/bastion
Logs centralisés

Questions de sécurité
Qui a accès à la console ?
Quels ports sont exposés ?
Quels logs prouvent les actions ?
Les données sont-elles chiffrées ?
Qui restaure en cas d’incident ?

Activité 4 • Cartographier les surfaces d’attaque

8 minutes

Sur le mini-cas ENSIA-Tech, identifiez :

1) trois points d’exposition ;
2) deux erreurs de configuration possibles ;
3) deux contrôles prioritaires ;
4) une information à journaliser.

1) Points d’exposition possibles : load balancer, API, bastion/VPN, console Cloud, stockage mal configuré.
2) Erreurs possibles : subnet public inutile, règles 0.0.0.0/0, absence de MFA, bucket public, logs désactivés.
3) Contrôles prioritaires : segmentation, moindre privilège, MFA, filtrage, chiffrement, journalisation.
4) Preuves/logs : connexions admin, appels API, changements de configuration, accès aux données, alertes de sécurité

Mini-cas ENSIA-Tech

Besoins
Portail Web étudiant
Base de données
Documents
Administration distante
Logs et sauvegardes

Architecture attendue
Zone publique : LB (**Load Balancer**)/WAF
Zone privée : application
Zone données : DB/storage
Accès admin : VPN/bastion
Logs centralisés

Quiz

- Quel composant Cloud sert à segmenter logiquement un réseau ?
- Pourquoi une base de données ne doit-elle pas être dans un subnet public ?
- Quelle différence entre management plane et data plane ?
- Donnez deux exemples de SecaaS.
- Qui est responsable d’un bucket public mal configuré ?
- Citez trois surfaces d’attaque Cloud.

Correction rapide
- VPC/VNet
- Réduction d’exposition
- Administration vs trafic applicatif
- IAM/KMS/WAF/SIEM/CSPM
- Client ou partagé selon contexte
- Identité/API/réseau/stockage/logs

Synthèse : la méthode de lecture d’une architecture Cloud



Prochaine séance C3
Sécurité des environnements virtualisés : hyperviseur, VM, isolation, réseaux virtuels, snapshots et hardening.